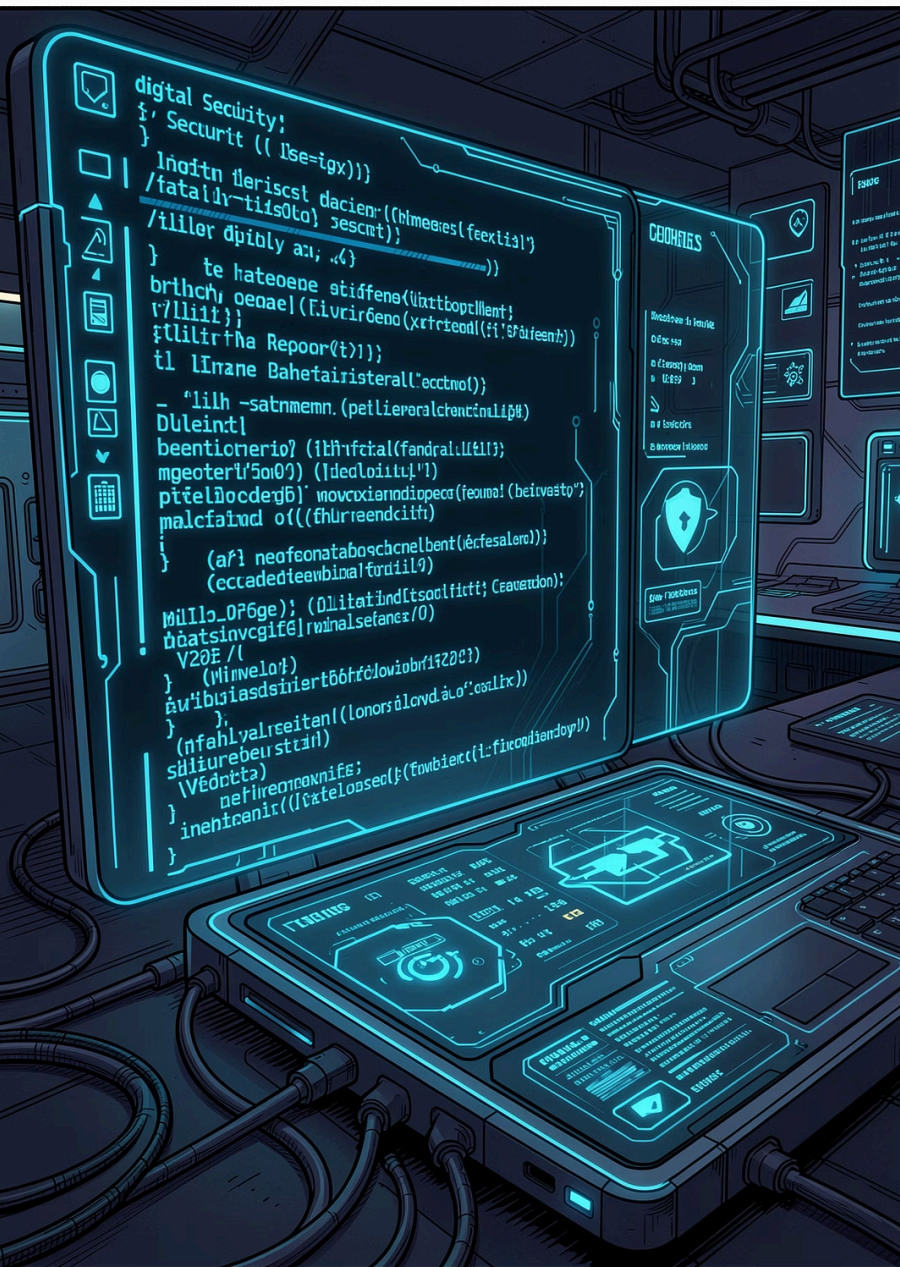




Приказ ФСТЭК №117: перевод для IT- специалиста

Чек-лист аудита ИИ-систем за 30 минут

Приказ ФСТЭК России №117 от 11.04.2025

Перевод регуляторики на язык кода

Автор

AI Security Lady Paladin

РАНХиГС

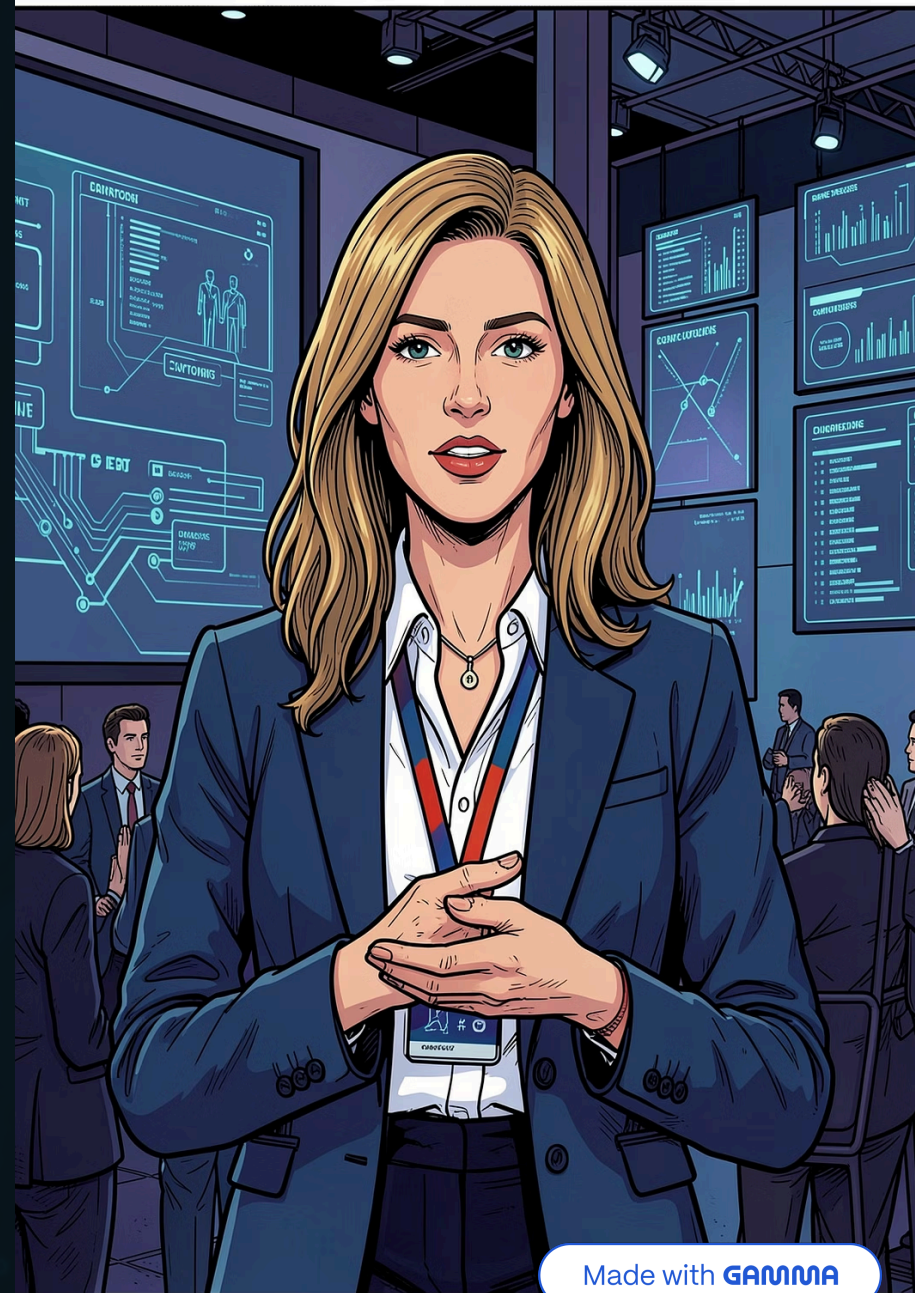
«Специалист по
системам ИИ»

Статус

✓ В силе с 01.03.2026

Цель

Создать чек-лист для экспресс-аудита ИИ-систем



Проблема → Решение

⚠ Проблема

- Юридический язык сложен для разработчиков
- Нет методик: «как проверить галлюцинации?», «как защитить модель?»

🎯 Решение

- Чек-лист: 6 требований → перевод на технический язык → конкретный тест
- Результат: аудит за 30 минут вместо 4 часов

Проблема

Перевод

Чек-лист

Аудит 30 мин

Главная задача — устранить разрыв между юридическим текстом регулятора и практическими действиями IT-команды.

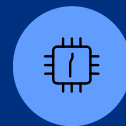
Инструменты: 2 LLM + мультимедиа



DeepSeek

Зачем: Русский юридический текст

Сильная сторона: Глубокий аудит (SHAP, adversarial)



Qwen

Зачем: Ролевые промпты, структура

Сильная сторона: Готовые команды (JSON Schema, DLP)



Результат: 80% совпадение требований → выборка репрезентативна

 Дополнительно: GigaChat (изображения), Freetts.ru (аудио), Gamma (презентация)

Промпты: как это работало

Запрос к Qwen

«Ты эксперт по ИИ-безопасности. Проанализируй пункты 60, 61, 71 Приказа №117. Выдели 5 требований. Переведи на технический язык + напиши способ проверки. Ответ: таблица».

Запрос к DeepSeek

«Ты аналитик по ИИ-рискам. Изучи пункты 60, 61, 71. Выдели 5 требований. Для каждого: перевод для IT + конкретный тест. Ответ: таблица».

✓ ☒ Обе модели выдали структурированные таблицы с практическими тестами

Требования п. 60: Защита данных

Требование из приказа	Перевод для разработчика	Как проверить
Защита от воздействия на данные/параметры модели	Исключить Data Poisoning, кражу весов	Тест: изменить 1% обучающей выборки → проверить устойчивость
Запрет передачи секретов разработчику модели	Не использовать реальные ПДн для дообучения внешних моделей	Запросить NDA + акт использования синтетических данных

Требования п. 61: Контроль ИИ

Требование из приказа	Перевод для разработчика	Как проверить
Контроль тематик запросов и форматов ответов	System Prompt + Guardrails («границы дозволенного»)	Red Teaming: задать запрещённый вопрос
Детекция недостоверных ответов («галлюцинаций»)	Оценка Confidence Score ответа	Блокировать ответы с score < 0.7
Ограничение полномочий при сбоях	Fallback-механизм: переключение на оператора	Симулировать ошибки → проверить «откат» прав

Red Teaming

Тестирование запрещённых запросов

Confidence Score

Порог достоверности < 0.7

Fallback

Переключение на оператора при сбое

Требование п. 71 + Итоговая таблица

🛡 Сертифицированные средства защиты

Требование	Перевод	Проверка
Применение сертифицированных средств защиты	Использовать только ПО с сертификатами ФСТЭК	Запросить сертификаты на антивирус, МЭ, средства защиты ИИ

📄 Полная таблица из 6 требований — в приложении к отчёту и на сайте



Мультимодальный результат: 4 формата

Для разных аудиторий — разные форматы подачи материала



PDF-отчёт

Детальный анализ для архива



Сайт-визитка

Интерактив для разработчиков →

aisecondityladypaladin.github.io/fstec-117-checklist



Аудио-гайд

Для руководителей «в дороге» → [Прослушать на Google Drive](#)



Видео-презентация

Визуализация процессов



Google Docs



Видео _ Приказ 117 _ 1+.mp4



Цель: снять барьер между юристами и разработчиками

Итоги и польза

⚡ Экономия времени

С 4 часов до 5 минут —
ускорение аудита в 48
раз

🛡 Снижение рисков

Чек-лист закрывает
ключевые пункты
приказа ФСТЭК-117

🎯 Готов к применению

Для приведения систем в соответствие с требованиями
регулятора

Навыки проекта:

- Работа с регуляторикой + перевод на технический язык
- Сравнительный анализ LLM: Qwen vs DeepSeek
- Создание мультимодального продукта (сайт, аудио, видео)